

VULNERABILITY RESEARCH

VULNERABILITY RESEARCH

“Vulnerabilities are undesirable in all facets of life.”

The word “**vulnerable**” derives from the Latin *vulnus*, meaning “wound.” [1]

“... a vulnerability is a behaviour or set of conditions present in a system, product, component, or service that “violates an implicit or explicit security policy.”” ISO/IEC 29147:2018 – Information Technology - Vulnerability Disclosure

[1] <https://www.etymonline.com/word/vulnerable>

VULNERABILITY RESEARCH

Vulnerability

“... is a behaviour or set of conditions present in a system, product, component, or service that “violates an implicit or explicit security policy.”” ISO/IEC 29147:2018 – Information Technology - Vulnerability Disclosure

Security threat

“... a malicious act that can exploit a vulnerability..”

Security risk

“... what may happen when a security threat exploits a vulnerability in a system. Potential damage, loss, destruction of an asset. ”



VULNERABILITY RESEARCH

Systems are not always perfect, they sometimes contain vulnerabilities (weakness)

Attackers exploit vulnerabilities to compromise operation and security properties of a system.

- **Confidentiality**
- **Integrity**
- **Availability**
- **Operation**
- **Authentication**
- **Authorization**
- **Nonrepudiation**



VULNERABILITY RESEARCH

Examples of vulnerabilities

- **Misconfigurations**
- **Unsecured APIs**
- **Outdated or unpatched software**
- **Zero-day vulnerabilities**
- **Weak or stolen user credentials**
- **Access control**
- **Unchecked user input**



VULNERABILITY RESEARCH

To improve security one may need to invest in vulnerability research

Vulnerability research

... an act of identifying security vulnerabilities in hardware and software devices, driven by the desire to prevent harms and engage in a responsible disclosure upon discovery.

Difference between “Research and Computer crime”



VULNERABILITY RESEARCH

To improve security one may need to invest in vulnerability research

Vulnerability research

... an act of identifying security vulnerabilities in hardware and software devices, driven by the desire to prevent harms and engage in a responsible disclosure upon discovery.

Difference between “Research and Computer crime”

Vulnerability Detection methods

- **Penetration testing**
- **Vulnerability scanning**
- **Reverse engineering**
-



VULNERABILITY RESEARCH

Methods of testing

Black box testing (e.g., Fuzzing)

- internal structure of code or program not known.
- usually done based on the requirements



VULNERABILITY RESEARCH

Methods of testing

Black box testing (e.g., Fuzzing)

- internal structure of code or program not known.
- usually done based on the requirements

White box testing (e.g., Unit testing)

- internal are known to the tester. (e.g., developers)
- detailed design of the system



VULNERABILITY RESEARCH

Methods of testing

Black box testing (e.g., Fuzzing)

- internal structure of code or program not known.
- usually done based on the requirements

White box testing (e.g., Unit testing)

- internal are known to the tester. (e.g., developers)
- detailed design of the system

Grey box testing (e.g., Regression testing)

- limited info is shared with the tester



VULNERABILITY RESEARCH

Why does it matter?

- Escalating number of threats
- Desire to eliminate vulnerabilities
- Vulnerable products erode commercial trust
- Social responsibility - Prevent harm, close the information gap
- To develop interventions or mitigate harm

Principle

- Prevention of harm



VULNERABILITY RESEARCH

Best practices include

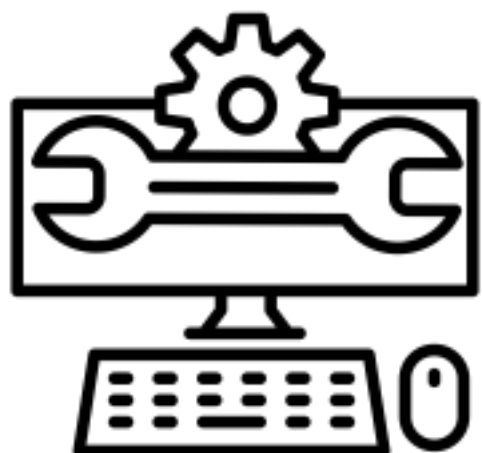
- **Disclose intent and research**
- **Seeking legal counsel prior to starting research**
- **Be proactive about data protection**
- **Contribute to existing knowledge in the field**
- **Train others**
- **Do not use pirated software or tools**



VULNERABILITY RESEARCH

Reverse Engineering

“The process of taking a piece of software or hardware and analysing its functions and information flow so that its functionality and behaviour can be understood.”



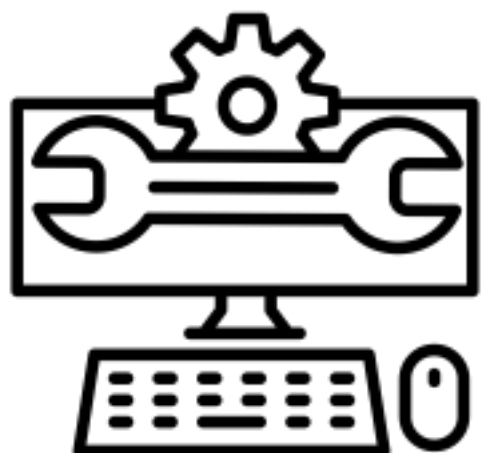
VULNERABILITY RESEARCH

Reverse Engineering

“The process of taking a piece of software or hardware and analysing its functions and information flow so that its functionality and behaviour can be understood.”

Other articulations

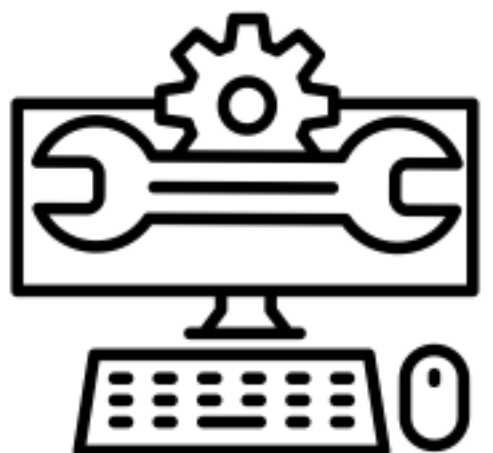
- *Deconstructing a device or piece of hardware or software*
- *Decompiling*
- *Disassembling or executable files and libraries*
- *Analysis of the system data*



VULNERABILITY RESEARCH

Why reverse engineering?

- *Protecting a system may require an understanding of how the system actually work.*
- *It helps when trying to defend against malware and viruses*
- *assessing the difficulty of restoring essential software algorithms*
- *device archaeology (developers leaving/ missing documentation)*



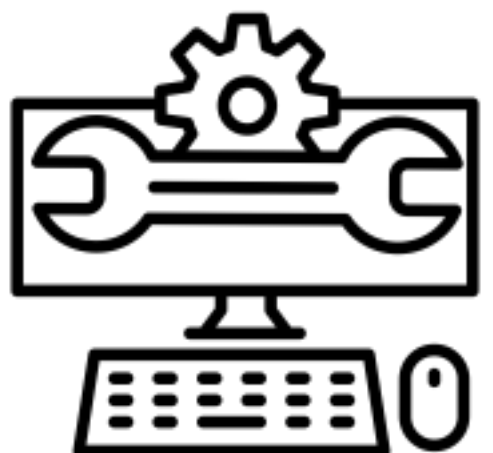
VULNERABILITY RESEARCH

Why reverse engineering?

- *Protecting a system may require an understanding of how the system actually work.*
- *It helps when trying to defend against malware and viruses*
- *assessing the difficulty of restoring essential software algorithms*
- *device archaeology (developers leaving/ missing documentation)*

Reverse engineering tools

- System monitoring tools
- Disassembling tools
- Debug tools
- Decompilers
- Hex editors
- Unpackers
- File analysing tools



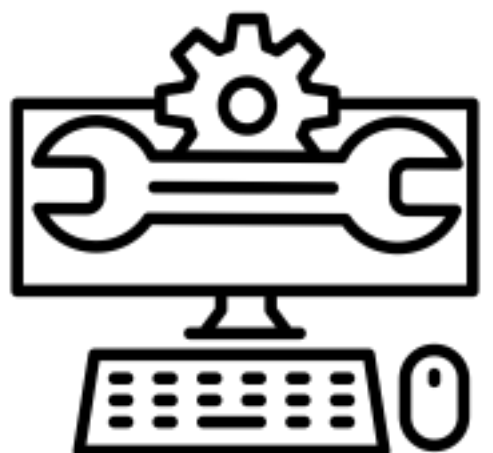
VULNERABILITY RESEARCH

Reverse Engineering and Law

While it was traditionally accepted as a normal behaviour it is considered illegal in some jurisdictions.

Laws that reverse engineering may infringe

- Copyright law
- Computer Misuse Act
- Contract laws - agreed terms
- Trade secret law



VULNERABILITY RESEARCH

Vulnerability Disclosure

“...techniques and policies for vendors to receive vulnerability reports and publish remediation information.” ISO/IEC 29147:2018 – Information Technology - Vulnerability Disclosure

Vulnerability disclosures are ***critical for supporting and maintaining products or services*** that are exposed to ***threats***. They are important and should be ***taken seriously***.



VULNERABILITY RESEARCH

Vulnerability Disclosure

“...techniques and policies for vendors to receive vulnerability reports and publish remediation information.” ISO/IEC 29147:2018 – Information Technology - Vulnerability Disclosure

Vulnerability disclosures are **critical for supporting and maintaining products or services** that are exposed to **threats**. They are important and should be **taken seriously**.

Challenges...

- Lack of consensus on the process of “responsible” disclosure
- The vendors may not be aware of the vulnerability ins some full disclosure cases
- State security agencies
- The relationship between discoverers and vendors remains complex. (Bug bounties)



VULNERABILITY RESEARCH

Vulnerability Disclosure

NIST SP 800-216: Recommendations for Federal Vulnerability Disclosure Guidelines

ISO/IEC 29147:2018 Information technology - Security techniques - Vulnerability disclosure



VULNERABILITY RESEARCH

Vulnerability Disclosure



NVD



VULNERABILITY RESEARCH

Methods of Vulnerability Disclosure

Non-Disclosure

- The vulnerability is discovered but not disclosed to the vendor



VULNERABILITY RESEARCH

Methods of Vulnerability Disclosure

Non-Disclosure

- The vulnerability is discovered but not disclosed to the vendor



Private Disclosure

- The vulnerability is reported privately to the organisation or vendor.
- The organisation may choose to publish the details of the vulnerabilities
- Common type around bug bounty programs
- The details of the disclosure may never be made public.



VULNERABILITY RESEARCH

Methods of Vulnerability Disclosure

Non-Disclosure

- The vulnerability is discovered but not disclosed to the vendor

Private Disclosure

- The vulnerability is reported privately to the organisation or vendor.
- The organisation may choose to publish the details of the vulnerabilities
- Common type around bug bounty programs
- The details of the disclosure may never be made public.

Full Disclosure

- The full details of the vulnerability are made public as soon as they are identified.
- Full details made available to everyone (including attackers), often before a patch is available.
- Commonly used when the vendor is not responsive (i.e., increase pressure to develop and publish a fix).
- Controversial - Some think it is irresponsible



Schneier writes:

'Public scrutiny is the only reliable way to improve security, while secrecy only makes us less secure.'

VULNERABILITY RESEARCH

Methods of Vulnerability Disclosure

Non-Disclosure

- The vulnerability is discovered but not disclosed to the vendor



Private Disclosure

- The vulnerability is reported privately to the organisation or vendor.
- The organisation may choose to publish the details of the vulnerabilities
- Common type around bug bounty programs
- The details of the disclosure may never be made public.



Full Disclosure

- The full details of the vulnerability are made public as soon as they are identified.
- Full details made available to everyone (including attackers), often before a patch is available.
- Commonly used when the vendor is not responsive (i.e., increase pressure to develop and publish a fix).
- Controversial - Some think it is irresponsible



Schneier writes:
'Public scrutiny is the only reliable way to improve security, while secrecy only makes us less secure.'

Responsible or Coordinated Disclosure

- The middle ground
- Researcher and vendor work together
- The initial report on the vulnerability is made privately to the organisation or vendor
- The full details are published once a patch has been made available



https://cheatsheetseries.owasp.org/cheatsheets/Vulnerability_Disclosure_Cheat_Sheet.html

VULNERABILITY RESEARCH

Vulnerability Disclosure Case study: Heartbleed (CVE-2014-0160)

- OpenSSL cryptography library bug
- Date discovered: 1 April 2014
- Existed since 2012
- Take advantage of the heartbeat process. (Victim bleeds sensitive info to the attacker)
- Exposes contents of the memory buffer



VULNERABILITY RESEARCH

Vulnerability Disclosure Case study: Heartbleed (CVE-2014-0160)

- OpenSSL cryptography library bug
- Date discovered: 1 April 2014
- Existed since 2012
- Take advantage of the heartbeat process. (Victim bleeds sensitive info to the attacker)
- Exposes contents of the memory buffer



VULNERABILITY RESEARCH

Vulnerability Disclosure Case study: Heartbleed (CVE-2014-0160)

- OpenSSL cryptography library bug
- Date discovered: 1 April 2014
- Existed since 2012
- Take advantage of the heartbeat process. (Victim bleeds sensitive info to the attacker)
- Exposes contents of the memory buffer



VULNERABILITY RESEARCH

Vulnerability Disclosure Case study: Heartbleed (CVE-2014-0160)

- OpenSSL cryptography library bug
- Date discovered: 1 April 2014
- Existed since 2012
- Take advantage of the heartbeat process. (Victim bleeds sensitive info to the attacker)
- Exposes contents of the memory buffer



VULNERABILITY RESEARCH

Vulnerability Disclosure Case study: Heartbleed (CVE-2014-0160)

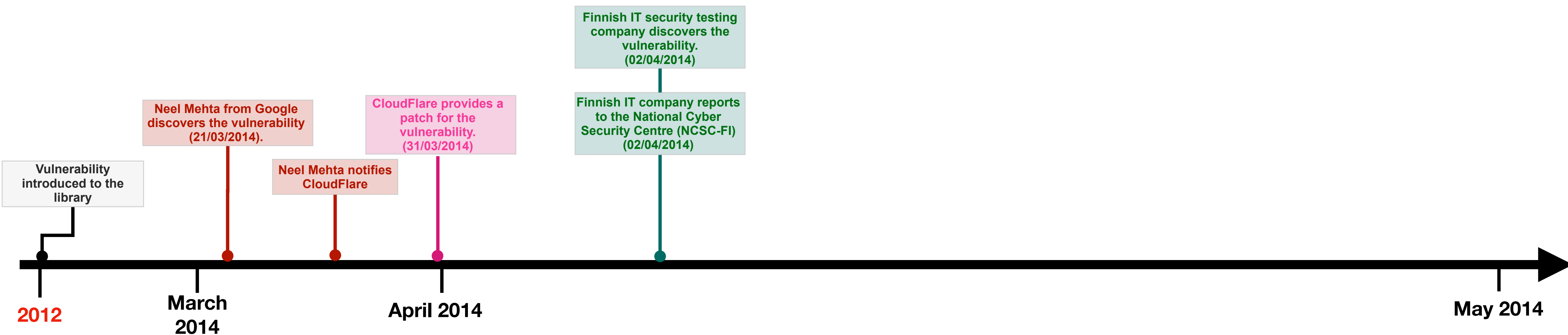
- OpenSSL cryptography library bug
- Date discovered: 1 April 2014
- Existed since 2012
- Take advantage of the heartbeat process. (Victim bleeds sensitive info to the attacker)
- Exposes contents of the memory buffer



VULNERABILITY RESEARCH

Vulnerability Disclosure Case study: Heartbleed (CVE-2014-0160)

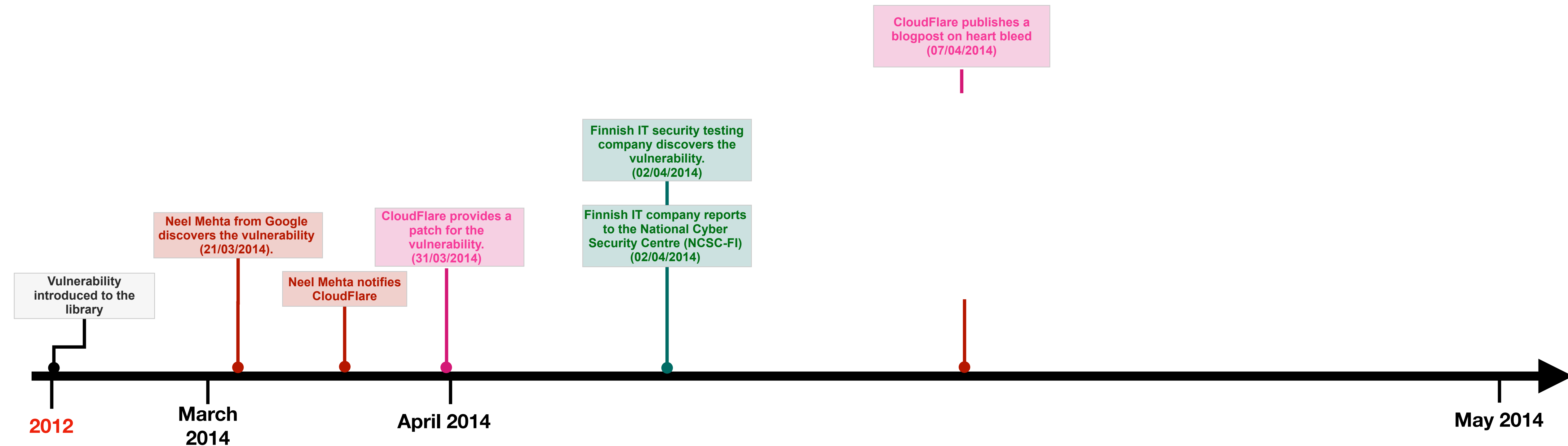
- OpenSSL cryptography library bug
- Date discovered: 1 April 2014
- Existed since 2012
- Take advantage of the heartbeat process. (Victim bleeds sensitive info to the attacker)
- Exposes contents of the memory buffer



VULNERABILITY RESEARCH

Vulnerability Disclosure Case study: Heartbleed (CVE-2014-0160)

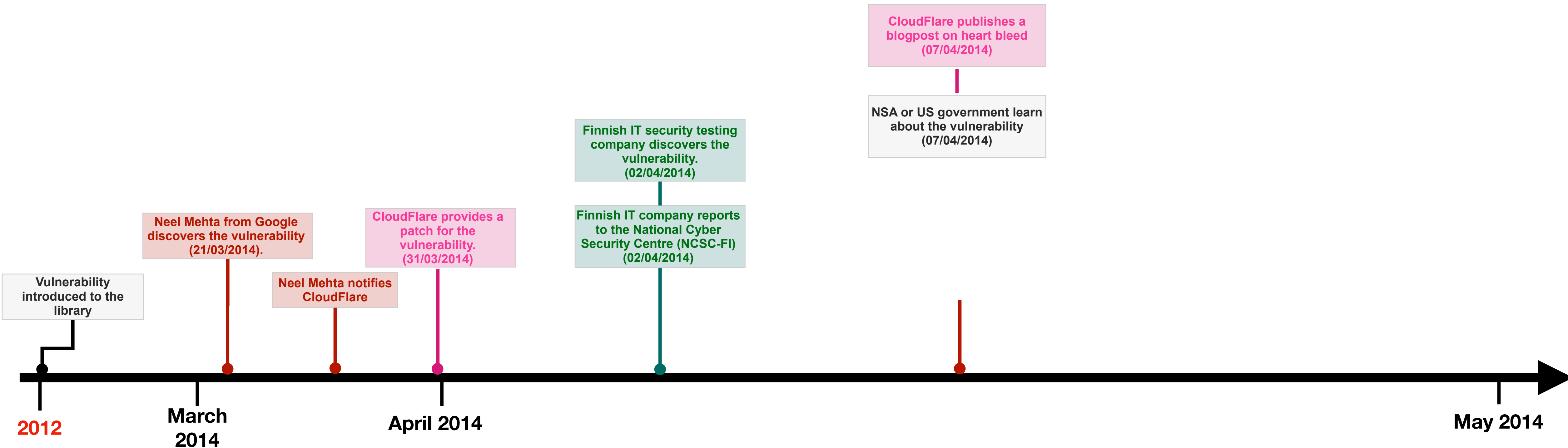
- OpenSSL cryptography library bug
- Date discovered: 1 April 2014
- Existed since 2012
- Take advantage of the heartbeat process. (Victim bleeds sensitive info to the attacker)
- Exposes contents of the memory buffer



VULNERABILITY RESEARCH

Vulnerability Disclosure Case study: Heartbleed (CVE-2014-0160)

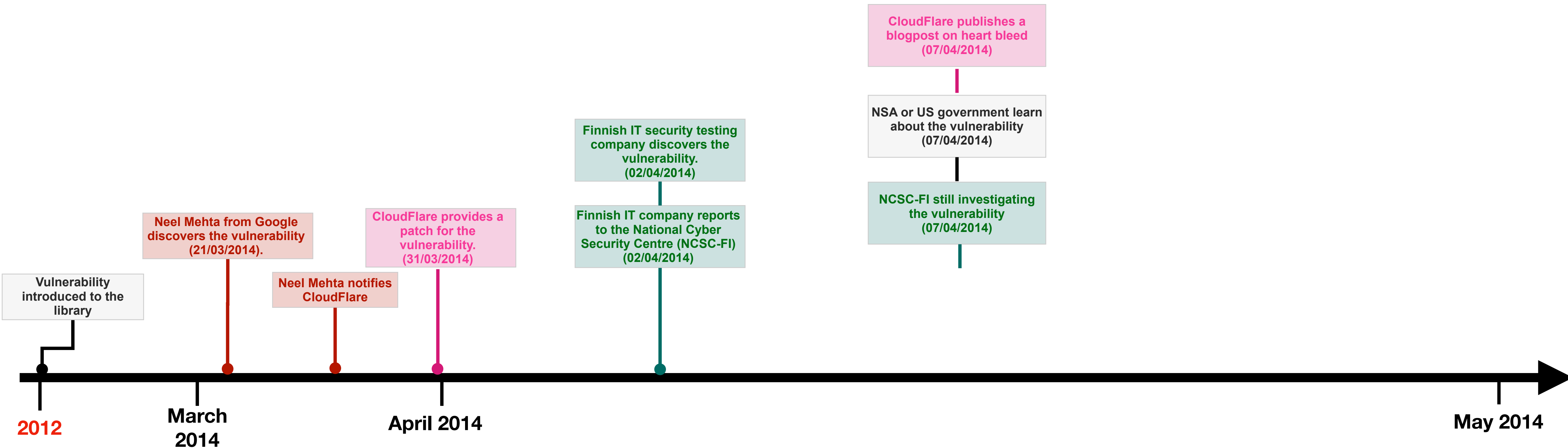
- OpenSSL cryptography library bug
- Date discovered: 1 April 2014
- Existed since 2012
- Take advantage of the heartbeat process. (Victim bleeds sensitive info to the attacker)
- Exposes contents of the memory buffer



VULNERABILITY RESEARCH

Vulnerability Disclosure Case study: Heartbleed (CVE-2014-0160)

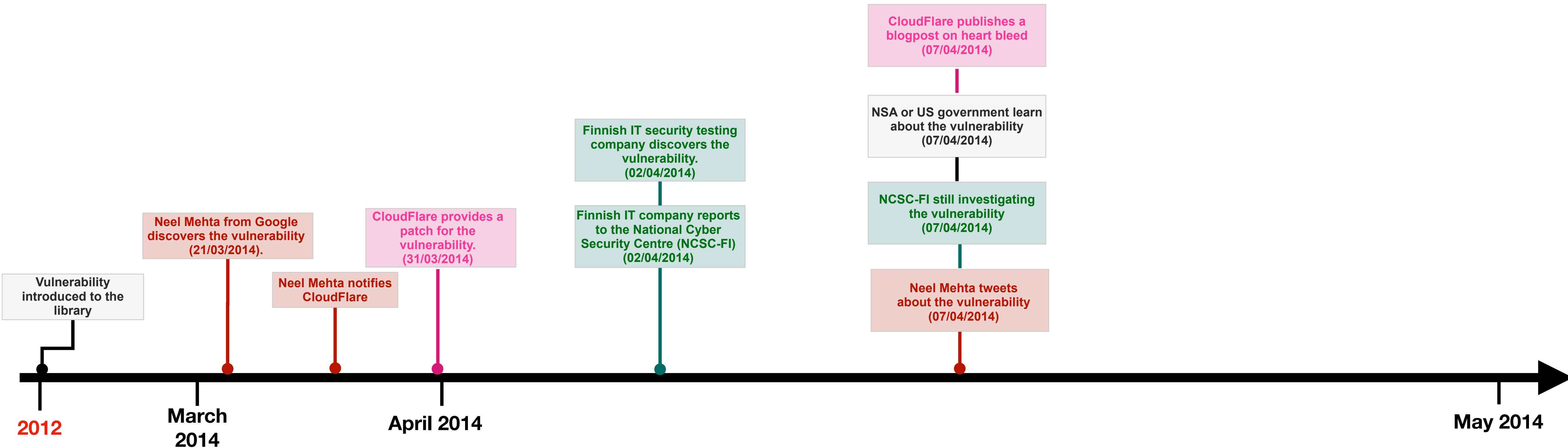
- OpenSSL cryptography library bug
- Date discovered: 1 April 2014
- Existed since 2012
- Take advantage of the heartbeat process. (Victim bleeds sensitive info to the attacker)
- Exposes contents of the memory buffer



VULNERABILITY RESEARCH

Vulnerability Disclosure Case study: Heartbleed (CVE-2014-0160)

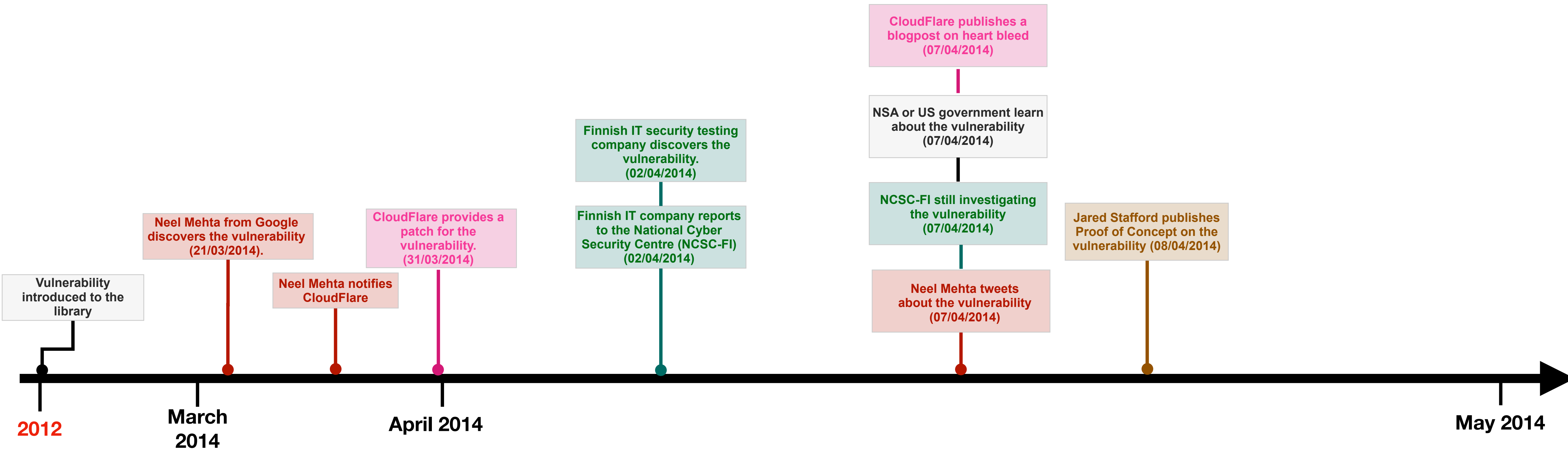
- OpenSSL cryptography library bug
- Date discovered: 1 April 2014
- Existed since 2012
- Take advantage of the heartbeat process. (Victim bleeds sensitive info to the attacker)
- Exposes contents of the memory buffer



VULNERABILITY RESEARCH

Vulnerability Disclosure Case study: Heartbleed (CVE-2014-0160)

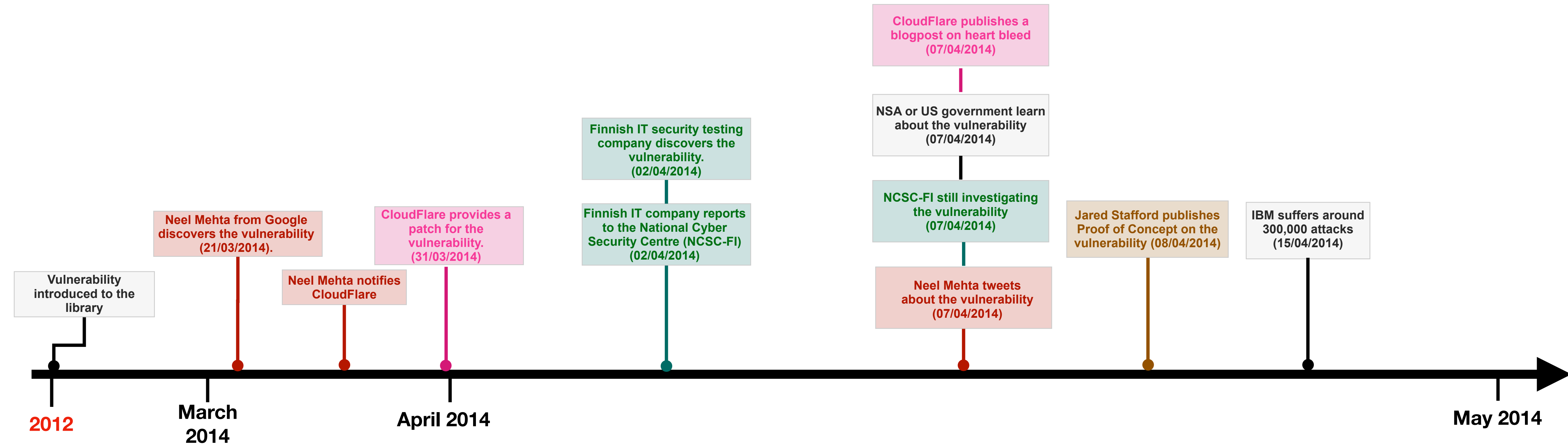
- OpenSSL cryptography library bug
- Date discovered: 1 April 2014
- Existed since 2012
- Take advantage of the heartbeat process. (Victim bleeds sensitive info to the attacker)
- Exposes contents of the memory buffer



VULNERABILITY RESEARCH

Vulnerability Disclosure Case study: Heartbleed (CVE-2014-0160)

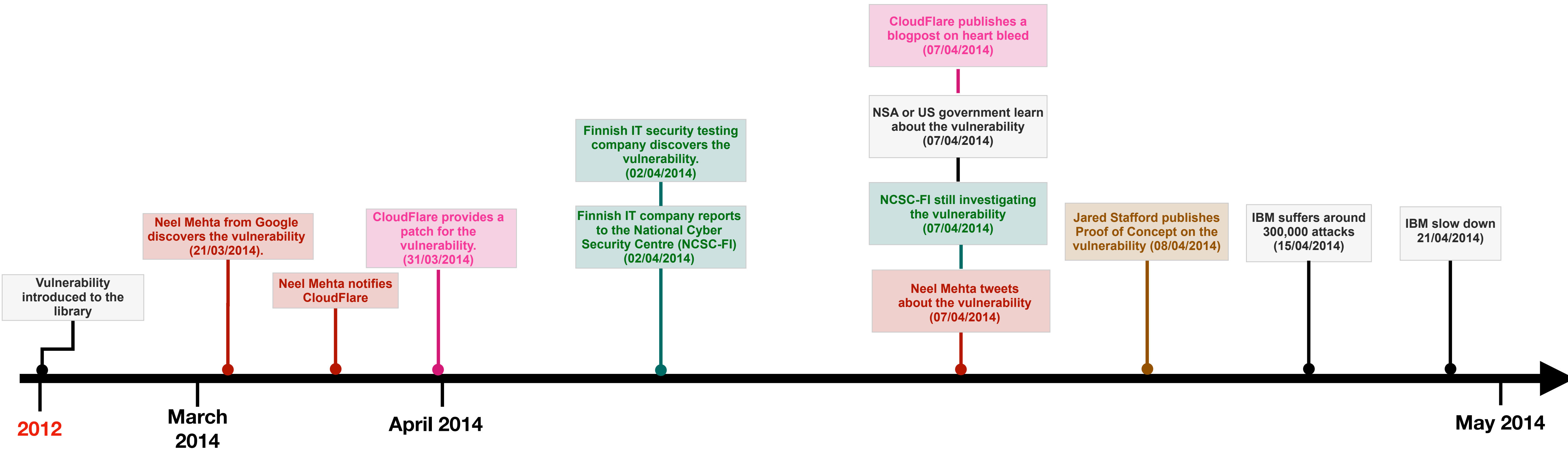
- OpenSSL cryptography library bug
- Date discovered: 1 April 2014
- Existed since 2012
- Take advantage of the heartbeat process. (Victim bleeds sensitive info to the attacker)
- Exposes contents of the memory buffer



VULNERABILITY RESEARCH

Vulnerability Disclosure Case study: Heartbleed (CVE-2014-0160)

- OpenSSL cryptography library bug
- Date discovered: 1 April 2014
- Existed since 2012
- Take advantage of the heartbeat process. (Victim bleeds sensitive info to the attacker)
- Exposes contents of the memory buffer



VULNERABILITY RESEARCH

Vulnerability Disclosure Effectiveness

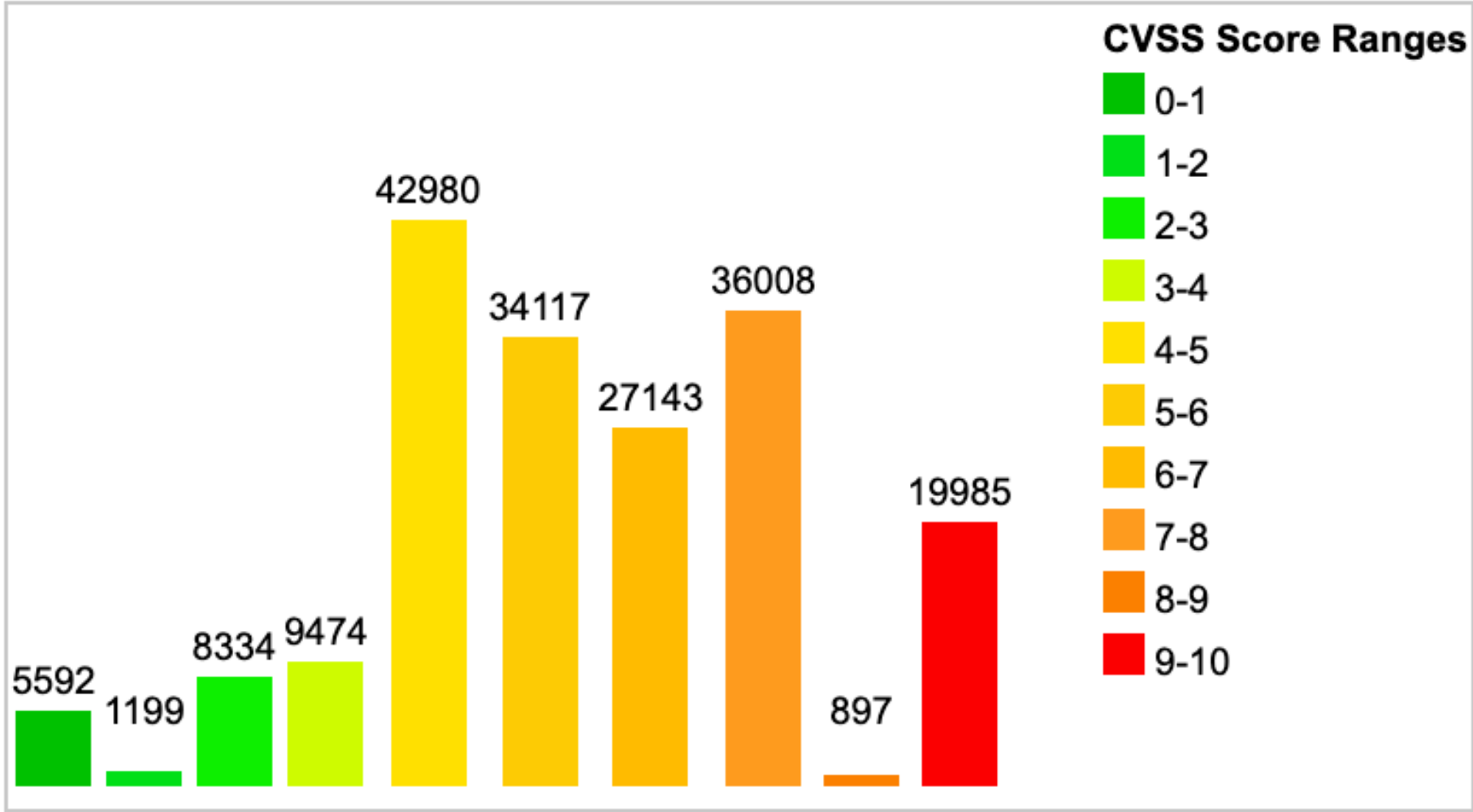
Current CVSS Score Distribution For All Vulnerabilities

Distribution of all vulnerabilities by CVSS Scores

CVSS Score	Number Of Vulnerabilities	Percentage
0-1	5592	3.00
1-2	1199	0.60
2-3	8334	4.50
3-4	9474	5.10
4-5	42980	23.10
5-6	34117	18.40
6-7	27143	14.60
7-8	36008	19.40
8-9	897	0.50
9-10	19985	10.80
Total	185729	

Weighted Average CVSS Score: **6.3**

Vulnerability Distribution By CVSS Scores



VULNERABILITY RESEARCH

How researchers should respond to finding a vulnerability?

- After discovering vulnerability the researcher should determine its potential impact
- The researcher should develop a detailed report with supporting evidence
- The researcher should give the vendor time to investigate the issue and advice on full disclosure timeline
- The researcher should make a full disclosure when a fix or patch has been found or time for full disclosure has elapsed



VULNERABILITY RESEARCH

How researchers should respond to finding a vulnerability?

- After discovering vulnerability the researcher should determine its potential impact
- The researcher should develop a detailed report with supporting evidence
- The researcher should give the vendor time to investigate the issue and advice on full disclosure timeline
- The researcher should make a full disclosure when a fix or patch has been found or time for full disclosure has elapsed

OWASP suggests researchers should:

- Ensure that any testing is legal and authorised.
- Respect the privacy of others.
- Make reasonable efforts to contact the security team of the organisation.
- Provide sufficient details to allow the vulnerabilities to be verified and reproduced.
- Not demand payment or rewards for reporting vulnerabilities outside of an established bug bounty program.

https://cheatsheetseries.owasp.org/cheatsheets/Vulnerability_Disclosure_Cheat_Sheet.html



VULNERABILITY RESEARCH

How vendors should respond to vulnerability disclosure?

- Identify a rapid-response team to attend to the issue
- Create protocols for the team to follow
- Define priority levels and corresponding responses
- Set up a framework for determining priority levels
- Create clear procedures for responding to each level



VULNERABILITY RESEARCH

How vendors should respond to vulnerability disclosure?

- Identify a rapid-response team to attend to the issue
- Create protocols for the team to follow
- Define priority levels and corresponding responses
- Set up a framework for determining priority levels
- Create clear procedures for responding to each level

OWASP suggest organisations should:

- Provide a clear method for researchers to securely report vulnerabilities.
- Clearly establish the scope and terms of any bug bounty programs.
- Respond to reports in a reasonable timeline.
- Communicate openly with researchers.
- Not threaten legal action against researchers.
- Request CVEs where appropriate.
- Publish clear security advisories and changelogs.
- Offer rewards and credit.



Further Reading

Listen to this podcast: <https://www.cybok.org/events/software-security-with-frank-piessens>

<https://cwe.mitre.org>

<https://www.cve.org>

<https://nvd.nist.gov> <https://owasp.org/Top10/>

